Introduction to Cybersecurity- Google

cyberSegurança é a pratica de garantir confidencialidade, integridade e disponibilidade das informações. Protegendo redes,dipositivos, pessoas e dados contra acesso não autorizados e exploração criminosa

threat actor - Any person or group who presents a security risk

Postura de segurança: A capacidade de uma organização de gerenciar sua defesa de recursos e dados críticos e reagir a mudanças

Segurança na nuvem: O processamento para garantir que os recursos armazenados na Nuvem sejam configurados adequadamente e que o acesso a esses recursos seja limitado a usuários autorizados

Ameaça interna: Um funcionário ou ex-funcionário, um fornecedor externo ou um parceiro confiável que represente um Risco à segurança

Beneficio da segurança

- protege contra ameaças externas e internas

Habilidades essenciais para profissionais de seguranças

Transferable skills:

skills de outras areas que podem ser transferidas e aplicadas.

- comunicação
- colaboração
- Analise
- Resolução de problemas
- **Mentalidade de crescimento**
- **Gerenciamento de tempo**
- **Diversidade de perspectivas**

technical skill:

- linguagem de programação
- Security information and event management (SIEM) tools
- Computer forencis
- **Sistemas de detecção de intrusão (IDSs)**
- **Conhecimento do cenário de ameaças**
- **Resposta a incidentes**

- garantem que a organização atenda à conformidade regulatória/ leis e diretrizes, que exigem a implementação de padrões de segurança especificos.
- mantem e melhora a produtividade dos negocios
- Reduzir despezaas associadas ao risco (como recuperação da perda de dados ou tempo de inatividade operacional
- Manter confiabilidade da marca

Analista de segurança são responsaveis por proteger e monitorar informações e sistemas

responsabilidades:

- proteger computadores e redes
- instalar softwares de prevenção
- realizar auditorias de segurança periodicamente

Além disso, o analista trabalha para evitar incidentes. Para que os analistas realizem esses tipos de tarefas com eficácia, eles precisam desenvolver conhecimentos sobre os seguintes conceitos-chave.

Conformidade é o processamento de adesão a padrões internos e regulamentos externos e permite que as organizações evitem multas e violações de segurança.

A importancia da CyberSegurança

Segurança é essencial para garantir continuidade dos negocios e posição etica.

Personally indentifiable Information(PII) - Informações de indentificação pessoal

qualquer info. usada para inferir a identidade de um individuo (nome completo, data de nascimento, endereço, numero, email, IP)

Sensitive Personally Indentifiable Information (SPII)- Informações sensiveis de identificação pessoal

Tipo especifico de PII que se enquadra em diretrizes de manuseios mais rigidas(numeros de providencias sociais, infos medica ou financeiras, dados biomentricos ou reconhecimento facial).

Roubo de identidade- Roubar informações pessoais para cometer fraude, enquanto se passa pela vitima.

Modulo 2

Virus do computador

codigo malicioso criado para interferir nas operações de um computador e causar dano em informações e softwares. Ele se prende em programas e documentos , depois se espalha e

Frameworks de segurança são diretrizes usadas para criar planos que ajudem a reduzir os riscos e as ameaças aos dados e à privacidade dos dados.

Controles de segurança são salvaguardas projetadas para reduzir riscos de segurança específicos. Eles são usados com os frameworks de segurança para estabelecer uma postura de segurança forte.

A postura de segurança é a capacidade da organização de gerenciar a defesa de recursos e dados críticos e reagir a mudanças. Uma postura de segurança forte leva a um risco menor para a organização.

Um **agente de ameaça**, ou atacante mal-intencionado, é qualquer pessoa ou grupo que represente um risco à segurança. Esse risco pode estar relacionado a computadores, aplicativos, redes e dados.

Uma **ameaça interna** pode ser um funcionário ou ex-funcionário, um fornecedor externo ou um parceiro confiável que represente um risco à segurança. Às vezes, uma ameaça interna é acidental. Por exemplo, um funcionário que clica acidentalmente em um link de e-mail malicioso seria considerado uma ameaça acidental. Outras vezes, o agente da ameaça interna se envolve *intencionalmente* em infecta um ou mais computadores em uma rede.

Malware- Software designado para danificar serviços ou redes.

á muitos tipos de malware. O principal objetivo do malware é obter dinheiro ou, em alguns casos, uma vantagem de inteligência que pode ser usada contra uma pessoa, uma organização ou um território.

Alguns dos tipos mais comuns de ataques de malware atualmente incluem:

- **Vírus:** Código malicioso escrito para interferir nas operações do computador e causar danos aos dados e ao software. Um vírus precisa ser iniciado por um usuário (ou seja, um agente de ameaça), que transmite o vírus por meio de um anexo malicioso ou download de arquivo. Quando alguém abre o anexo malicioso ou o download, o vírus se esconde em outros arquivos no sistema agora infectado. Quando os arquivos infectados são abertos, o vírus pode inserir seu próprio código para danificar e/ou destruir os dados do sistema.
- **Worms:** Malware que pode se duplicar e se espalhar pelos sistemas por conta própria. Ao contrário de um vírus, um worm não precisa ser baixado por um usuário. Em vez disso, ele se

atividades de risco, como o acesso não autorizado a dados.

Segurança de rede é a prática de manter a infraestrutura de rede de uma organização protegida contra acesso não autorizado. Isso inclui dados, serviços, sistemas e dispositivos armazenados na rede de computadores de uma organização.

Segurança na nuvem é o processamento para garantir que os recursos armazenados na nuvem sejam configurados ou definidos corretamente, e que o acesso a esses recursos seja limitado a usuários autorizados. A Nuvem é uma rede composta por um conjunto de servidores ou computadores que armazenam recursos e dados em locais físicos remotos, conhecidos como data centers, que podem ser acessados pela Internet. A Segurança na nuvem é um subcampo crescente da segurança cibernética que se concentra especificamente na proteção de dados, aplicativos e infraestrutura na nuvem.

Programação é um processamento que pode ser usado para criar um conjunto específico de instruções para um computador executar tarefas. Essas tarefas podem incluir:

- Automação de tarefas repetitivas (por exemplo, auto-replica e se espalha de um computador já infectado para outros dispositivos na mesma rede.
- **Ransomware:** Ataque malicioso em que os agentes da ameaça criptografam os dados de uma organização e exigem pagamento para restaurar o acesso.
- **Spyware:** Malware usado para coletar e vender informações sem consentimento. O spyware pode ser usado para acessar dispositivos. Isso permite que os agentes de ameaças coletem dados pessoais, como e-mails particulares, textos, registros de voz e imagem e localizações.

Social engineering- tecnica de manipulação que explora o erro humano para paranha infos privadas, acesso ou objetos de valor. O erro humano geralmente é resultado de confiar em alguém sem questionar. A missão de um agente de ameaças, agindo como engenheiro social, é criar um ambiente de falsa confiança e mentiras para explorar o maior número possível de pessoas.

Alguns dos tipos mais comuns de ataques de engenharia social atualmente incluem:

- **Phishing de mídia social:** um agente de ameaças coleta

pesquisar uma lista de domínios maliciosos)

- Análise do Tráfego da Web
- Alerta de atividades suspeitas

Na violação de dados é importante manter a calma e conter a violação. No caso, se for um servidor deliga-lo, “parar a hemorragia de dados” . Parar a violação para depois investiga-la.

Oito dominios de segurança do CISSP

Certified Informações Systems Security Professional é uma certificação de segurança da informação reconhecida mundialmente e muito procurada, concedida pelo International Informações Systems Security Certification Consortium

Segurança e gerenciamento de risco- É focado em definir metas e objetivos de segurança na redução de risco, com conformidade e continuidade dos negocios e na lei.

Segurança de recursos - É focado na segurança virtual e fisica de ativos. Tambem relacionados ao armazenamento, manutenção, retenção e destruição de dados.

Arquitetura e engenharia de segurança - Otimizar a segurança de dados garantindo a

informações detalhadas sobre seu alvo em sites de mídia social. Em seguida, ele inicia um ataque.

- **Ataque de watering hole:** Um agente de ameaças ataca um site frequentemente visitado por um grupo específico de usuários.
- **USB baiting:** Um agente de ameaças deixa estrategicamente um pendrive com malware para que um funcionário o encontre e instale, infectando uma rede sem saber.
- **Engenharia social física:** Um agente de ameaças se faz passar por um funcionário, cliente ou fornecedor para obter acesso não autorizado a um local físico.

Princípios da engenharia social

A engenharia social é incrivelmente eficaz. Isso ocorre porque as pessoas geralmente confiam e estão condicionadas a respeitar a Autoridade. O número de ataques de engenharia social está aumentando a cada novo aplicativo de mídia social que permite o acesso público aos dados das pessoas. Embora o compartilhamento de dados pessoais, como sua localização ou

implementação de ferramentas, sistemas e processos eficazes.

Firewall - dispositivo usado para monitorar e filtrar trafego de entrada e saida da rede . Configurar um firewall corretamente ajuda a evitar ataques que possam afetar a produtividade

Comunicação e segurança de Rede- Gerenciamento e proteção de comunicações sem fio

gerenciamento de identidade e acesso- Manter dados seguros, garantindo que os usuarios sigam politicas estabelecidas para controlar e gerenciar ativos fisicos, como espaços de escritorios e ativos logicos como redes e apps.

Avaliação e teste de segurança - Realiza testes de controles de segurança, coleta e analise de dados e realização de auditorias para monitorar riscos, ameaças e vulnerabilidades.

Operações de segurança - Conduz investigações e implementações de medidas preventidas

Segurança no desenvolvimento de software - Uso de praticas de programação seguras, que são um conjunto dde diretrizes recomendadas usadas para criar apps e serviços seguros

Tipos de ataque

fotos, possa ser conveniente, também é um risco.

Os motivos pelos quais os ataques de engenharia social são eficazes incluem:

- **Autoridade:** Os agentes da ameaça se fazem passar por indivíduos com poder. Isso ocorre porque as pessoas, em geral, foram condicionadas a respeitar e seguir figuras de autoridade.
- **Intimidação:** Os agentes da ameaça usam táticas de intimidação. Isso inclui persuadir e intimidar as vítimas para que façam o que lhes é pedido.
- **Consenso/prova social:** Como as pessoas às vezes fazem coisas que acreditam que muitos outros estão fazendo, os agentes de ameaças usam a confiança dos outros para fingir que são legítimos. Por exemplo, um agente de ameaças pode tentar obter acesso a dados privados dizendo a um funcionário que outras pessoas da empresa lhe deram acesso a esses dados no passado.
- **Escassez:** Uma tática usada para sugerir que os bens ou serviços têm oferta limitada.
- **Familiaridade:** Os agentes da ameaça estabelecem uma falsa

Quebra de senha

Uma **quebra de senha** é uma tentativa de acessar dispositivos, sistemas, redes ou dados protegidos por senha. Algumas formas de quebra de senha sobre as quais você aprenderá mais adiante no programa de certificação são

- Força bruta
- Tabela arco-íris

As quebras de senha se enquadram no domínio de comunicação e segurança de rede.

Ataque de engenharia social

A engenharia social é uma técnica de manipulação que explora o erro humano para obter informações privadas, acesso ou objetos de valor. Algumas formas de ataques de engenharia social sobre as quais você continuará aprendendo ao longo do programa são

- Phishing
- Smishing
- Vishing
- Spear phishing
- Whaling
- Phishing de mídia social
- Comprometimento de e-mail comercial (BEC)
- Ataque de watering hole

conexão emocional com os usuários que pode ser exploit.

- **Confiança:** Os agentes da ameaça estabelecem um relacionamento emocional com os usuários que pode ser explorado *ao longo do tempo*. Eles usam esse relacionamento para desenvolver a confiança e obter informações pessoais.
- **Urgência:** Um agente de ameaças persuade os outros a responder rapidamente e sem questionar.

Phishing-

Uso das comunicações digitais para induzir pessoas a revelar dados confidencias ou implantar softwares maliciosos

Alguns dos tipos mais comuns de ataques de phishing atualmente incluem:

- **Business-to-business Compromise (BEC):** Um agente de ameaças envia uma mensagem de e-mail que parece ser de uma fonte conhecida para fazer uma solicitação aparentemente legítima de informações, a fim de obter uma vantagem financeira.
- **Spear phishing:** ataque de e-mail mal-intencionado que tem como alvo um usuário específico ou um grupo de usuários. O e-

- USB (Universal Serial Bus) baiting
- Engenharia social física

Os ataques de engenharia social estão relacionados ao domínio de segurança e Gerenciamento de riscos.

Ataque físico

Um **ataque físico** é um incidente de segurança que afeta não apenas os ambientes digitais, mas também os ambientes físicos onde o incidente é implantado. Algumas formas de ataques físicos são:

- Cabo USB malicioso
- Unidade flash maliciosa
- Clonagem e desnatação de cartões

Os ataques físicos se enquadram no domínio de segurança de recursos.

Inteligência Artificial Adversária

A Inteligência Artificial Ad versária é uma técnica que manipula a inteligência artificial e a tecnologia de Aprendizado de Máquina para realizar ataques com mais eficiência. A Inteligência Artificial Adversária se enquadra nos domínios de comunicação e segurança de rede e Gerenciamento de Identidade e Acesso.

mail parece ter sido originado de uma fonte confiável.

- **Whaling:** Uma forma de spear phishing. Os agentes da ameaça têm como alvo os executivos da empresa para obter acesso a dados confidenciais.
- **Vishing:** o exploit da comunicação eletrônica de voz para obter informações confidenciais ou para se passar por uma fonte conhecida.
- **Smishing:** o uso de mensagens de texto para enganar os usuários, a fim de obter informações confidenciais ou se passar por uma fonte conhecida.

Tipos de agentes de ameaças

Ameaças persistentes avançadas

As Ameaças persistentes avançadas (APTs) têm experiência significativa no acesso à rede de computadores de uma organização sem autorização. As APTs tendem a pesquisar seus alvos (por exemplo, grandes corporações ou entidades governamentais) com antecedência e podem permanecer sem serem detectadas por um longo período de tempo. Suas intenções e motivações podem incluir:

Ataque à cadeia de suprimentos

Um **ataque à cadeia de suprimentos** visa sistemas, aplicativos, hardware e/ou software para localizar uma vulnerabilidade em que o malware possa ser implantado. Como cada item vendido passa por um processamento que envolve terceiros, isso significa que a violação de segurança pode ocorrer em qualquer ponto da Cadeia de suprimentos. Esses ataques são caros porque podem afetar várias organizações e os indivíduos que trabalham para elas. Os ataques à Cadeia de Suprimentos podem se enquadrar em vários domínios, incluindo, entre outros, os domínios de segurança e Gerenciamento de Riscos, arquitetura e engenharia de segurança e operações de segurança.

Ataque criptográfico

Um **ataque criptográfico** afeta formas seguras de comunicação entre um remetente e o destinatário pretendido. Algumas formas de ataques criptográficos são:

- Aniversário
- Colisão
- Downgrade

Os ataques criptográficos se enquadram no domínio da

- Danificar a infraestrutura essencial, como a rede de poder e os recursos naturais
- Obter acesso à propriedade intelectual, como segredos comerciais ou patentes

Ameaças internas

As ameaças internas abusam de seu acesso autorizado para obter dados que podem prejudicar uma organização. Suas intenções e motivações podem incluir:

- Sabotagem
- Corrupção
- Espionagem
- Acesso ou vazamento de dados não autorizados

Hacktivistas

Hacktivistas são agentes de ameaças movidos por uma agenda política. Eles abusam da tecnologia digital para atingir seus objetivos, que podem incluir:

- Manifestações
- Propaganda
- Campanhas de mudança social
- Fama

comunicação e da segurança de
rede.

Modulo 3

Frameworks

Frameworks de segurança são **diretrizes usadas para construir planos para mitigar riscos e ameaças aos dados e à privacidade**. Fornecendo uma abordagem segura para implementar um ciclo de vida de segurança

ciclo de vida de segurança - conjunto de políticas e padrões em constante evolução que define como uma orgaização lida com riscos , segue diretrizes estabelecidas e atende à conformidade regulatoria ou leis.

Proposito das Frameworks de segurança

- Proteger PII
- Proteger informações financeiras
- Indentificar pontos fracos de segurança
- Gerenciar riscos organizacionais
- Alinhar segurança com às metas de negócios.

Componentes de uma frameworks

1. Identificar e documentar metas de segurança
2. Definir diretrizes para atingir metas de segurança
3. Implementar fortes processos de seguranças
4. Monitorar e comunicar resultados

Conformidade é o processo de adesão a padrões internos e normas externas.

Controles de segurança

São proteções progetadas para reduzir um risco especifico de segurança

Design Seguro

Triad CIA

É um modelo fundamental que ajuda informar como as organizações consideram riscos ao configurar sistemas e politicas de segurança.

CIA- Confidencialidade, integridade e disponibilidade(availability)

Confidencialidade - Apenas usuarios autorizados podem acessar ativos e dados especificos

Integridade- Dados são corretos, autenticados e confiaveis. Para manter a integridade profissionais de seguranças podem usar formas de proteções de dados como criptografia para evitar dados adulterados.

Disponibilidade (availability) - Dados são acessiveis para aqueles que estão autorizados a acessa-los.

Asset (Ativos/recursos) - Recursos percebidos como tendo valor para uma organização. Sendo o valor associado ao recurso em questão

NIST Cybersecurity framework

O National Institute of Standards and Technology (NIST) é uma agência sediada nos EUA que desenvolve várias estruturas de conformidade voluntária que as organizações do mundo todo podem usar para ajudar a gerenciar os riscos. Quanto mais alinhada uma organização estiver

Quando usamos PII devemos ter certeza que somos muito cuidadosos sobre como elas são tratadas e onde são armazenadas, e que entendemos onde elas são armazanadas o tempo todo.

É importante garantir a proteção dos PII para cumprir a regulamentação ou a lei.

Portanto, é importante entender como os dados se relacionam com algumas dessas obrigações. Se uma organização não cumprir suas obrigações, várias coisas podem acontecer.

Primeiro, você pode ver um regulador governamental se interessar mais em entender as práticas de como uma empresa está lidando com os dados. Em segundo lugar, consumidores, clientes e empresas podem realmente começar a perguntar diretamente à empresa como estão lidando com os dados. E isso pode se tornar parte do relacionamento com o cliente e ser cada vez mais importante se esses dados forem muito confidenciais. E terceiro, a última consequência é a ação legal. E não é incomum vermos vítimas de incidentes de cibersegurança processando empresas por manipularem seus dados de forma incorreta. Você pode se manter atualizado com a conformidade, a regulamentação e as leis sobre PII consultando o site relevante na jurisdição para a qual você tem uma pergunta. Muitos sites governamentais agora publicam as leis, os regulamentos e os requisitos de conformidade dos dados que estão sendo manipulados.

As regulamentações e leis que regem como as PII podem ser tratadas são muito complexas. Em todo o mundo, países , estados e condados as estão regulamentando em diferentes níveis. É importante entender e estar ciente de que essas leis existem. No entanto, se você precisar fazer uma pergunta sobre uma lei específica, é importante procurar orientação de um advogado para essa jurisdição específica. Pode ser muito diferente da jurisdição em que você está.

Security ethics(eticas de segurança)

Diretrizes para tomar decisões apropriadas como um profissional de segurança. Ser ético exige que os profissionais de segurança permaneçam imparciais e mantenham a segurança e a confidencialidade dos dados privados. Ter um forte senso de ética pode ajudá-lo a tomar suas decisões como profissional de segurança cibernética para que você possa mitigar as ameaças impostas pelas táticas e técnicas em constante evolução dos agentes de ameaças.

com a conformidade, menor será o risco. É um framework voluntario que consiste em padrões, diretrizes e melhores praticas para gerenciar riscos de cibersegurança. Equipes de segurança os usam como base para gerenciar riscos de curto e longo prazo.

Exemplos de estruturas incluem a Estrutura de Segurança Cibernética (CSF) do NIST e a Estrutura de Gerenciamento de Riscos (RMF) do NIST.

Além do NIST CSF e do NIST RMF, há vários outros controles, estruturas e padrões de conformidade com os quais é importante que os profissionais de segurança estejam familiarizados para ajudar a manter seguras as organizações e as pessoas a quem elas servem.

A Comissão Federal Reguladora de Energia - Corporação Norte-Americana de Confiabilidade Elétrica (FERC-NERC)

A FERC-NERC é uma regulamentação que se aplica a organizações que trabalham com eletricidade ou que estão envolvidas com a rede de poder dos EUA e da América do Norte. Esses tipos de organizações têm a obrigação de se preparar, mitigar e relatar qualquer possível incidente de segurança que possa afetar negativamente a rede

Principios eticos em segurança

- Confidencialidade
- proteções de privacidade
- Leis

Confidencialidade - como profissional de segurança encontrarei varias infos proprietarias ou privadas, como PII. Sendo meu dever etico manter essas informações confidenciais e seguras. significa que somente usuários autorizados podem acessar recursos ou dados específicos. A confidencialidade, no que se refere à Ética profissional, significa que é necessário haver um alto nível de respeito à privacidade para proteger os recursos e dados privados.

proteções de privacidade - Proteger informações pessoais contra o uso não autorizado. Informações de identificação pessoal (PII) e informações sensíveis de identificação pessoal (SPII) são tipos de dados pessoais que podem causar danos às pessoas se forem roubados. Para proteger efetivamente os dados de PII e SPII , os profissionais de segurança têm a obrigação ética de proteger informações privadas, identificar vulnerabilidades de segurança, gerenciar riscos organizacionais e alinhar a

de poder. Elas também são legalmente obrigadas a aderir aos Padrões de Confiabilidade de Proteção de Infraestrutura Crítica (CIP) definidos pela FERC.

O Programa Federal de Gerenciamento de Riscos e Autorizações (FedRAMP®)

O FedRAMP é um programa do governo federal dos EUA que padroniza a avaliação de segurança, a autorização, o monitoramento e o manuseio de serviços e ofertas de produtos na nuvem. Seu objetivo é fornecer consistência entre o setor governamental e os provedores de nuvem de terceiros.

Centro de Segurança da Internet (CIS®)

O CIS é uma organização sem fins lucrativos com várias áreas de ênfase. Ele fornece um conjunto de controles que podem ser usados para proteger sistemas e redes contra ataques. Seu objetivo é ajudar as organizações a estabelecer um melhor plano de defesa. O CIS também fornece controles acionáveis que os profissionais de segurança podem seguir se ocorrer um incidente de segurança.

Regulamento Geral de Proteção de Dados (GDPR)

segurança aos objetivos de negócios.

Lei- Leis são regras reconhecidas por uma comunidade e aplicadas por uma entidade governamental. Para proteger efetivamente os dados de PII e SPII , os profissionais de segurança têm a obrigação ética de proteger informações privadas, identificar vulnerabilidades de segurança, gerenciar riscos organizacionais e alinhar a segurança aos objetivos de negócios.

Preocupações éticas e leis relacionadas a contra-ataques

Ponto de vista dos Estados Unidos sobre contra-ataques

Nos EUA, a implantação de um contra-ataque contra um agente de ameaça é ilegal devido a leis como a Computer Fraud and Abuse Act de 1986 e a Cybersecurity Informações Sharing Act de 2015, entre outras. Você só pode se defender. O ato de contra-atacar nos EUA é visto como um ato de vigilantismo. Um vigilante é uma pessoa que não é membro da polícia e que decide impedir um crime por conta própria. E como os agentes de ameaças são criminosos, os contra-ataques podem levar a um maior Encaminhamento do ataque, o que

O Regulamento Geral de Proteção de Dados (GDPR) é um regulamento geral de dados da União Europeia (UE) que protege o processamento de dados de residentes da UE e seu direito à privacidade dentro e fora do território da UE. Por exemplo, se uma organização não estiver sendo transparente sobre os dados que mantém sobre um cidadão da UE e por que está mantendo esses dados, isso é uma infração que pode resultar em uma multa para a organização. Além disso, se ocorrer uma violação e os dados de um cidadão da UE forem comprometidos, ele deverá ser informado. A organização afetada tem 72 horas para notificar o cidadão da UE sobre a violação.

Padrão de segurança de dados da indústria de cartões de pagamento (PCI DSS)

O PCI DSS é um padrão de segurança internacional destinado a garantir que as organizações que armazenam, aceitam, processam e transmitem informações de cartão de crédito o façam em um ambiente seguro. O objetivo desse padrão de conformidade é reduzir a fraude com cartões de crédito.

Lei de Portabilidade e Responsabilidade de Seguros de Saúde (HIPAA)

pode causar ainda mais danos e prejuízos. Por fim, se o agente da ameaça em questão for um hacktivista patrocinado pelo Estado, um contra-ataque pode levar a sérias implicações internacionais. Um **hacktivista** é uma pessoa que usa o hacking para atingir um objetivo político. O objetivo político pode ser promover a mudança social ou a desobediência civil.

Por esses motivos, os únicos indivíduos nos EUA que têm permissão para contra-atacar são funcionários aprovados do governo federal ou militares.

Ponto de vista internacional sobre contra-ataques

A Corte Internacional de Justiça (ICJ), que atualiza suas orientações regularmente, afirma que uma pessoa ou grupo pode contra-atacar se:

- O contra-ataque afetará apenas a parte que atacou primeiro.
- O contra-ataque for uma comunicação direta pedindo que o atacante inicial pare.
- O contra-ataque não aumentar a situação.
- Os efeitos do contra-ataque puderem ser revertidos.

Normalmente, as organizações não contra-atacam porque os cenários e parâmetros acima são difíceis de

A HIPAA é uma lei federal dos EUA criada em 1996 para proteger as informações de saúde dos pacientes. Essa lei proíbe que as informações dos pacientes sejam compartilhadas sem o consentimento deles. Ela é regida por três regras:

1. Privacidade
2. Segurança
3. Notificação de violação

As organizações que armazenam dados de pacientes têm a obrigação legal de informar os pacientes sobre uma violação, pois se as **Informações de Saúde Protegidas** (PHI) dos pacientes forem expostas, isso pode levar a roubo de identidade e fraude de seguro. As PHI estão relacionadas à saúde ou condição física ou mental passada, presente ou futura de um indivíduo, seja um plano de atendimento ou pagamentos por atendimento. Além de entender a HIPAA como uma lei, os profissionais de segurança também precisam conhecer a Health Information Trust Alliance (HITRUST®), que é uma estrutura de segurança e um programa de garantia que ajuda as instituições a cumprir a conformidade com a HIPAA.

Organização Internacional de Padronização (ISO)

medir. Há muita Incerteza sobre o que é e o que não é legal e, às vezes, é muito difícil controlar os resultados negativos. As ações de contra-ataque geralmente levam a um resultado pior, especialmente quando você não é um profissional experiente no Campo.

A ISO foi criada para estabelecer padrões internacionais relacionados à tecnologia, à fabricação e ao gerenciamento entre fronteiras. Ela ajuda as organizações a melhorar seus processos e procedimentos de retenção de pessoal, planejamento, desperdício e serviços.

Controles de sistemas e organizações (SOC tipo 1, SOC tipo 2)

O conselho de padrões de auditoria do American Institute of Certified Public Accountants® (AICPA) desenvolveu esse padrão. O SOC1 e o SOC2 são uma série de relatórios que se concentram nas políticas de acesso de usuários de uma organização em diferentes níveis organizacionais, como

- Associado
- Supervisor
- Gerente
- Executivo
- Vendedor
- Outros

São usados para avaliar a conformidade financeira e os níveis de risco de uma organização. Também abrangem a confidencialidade, a privacidade, a integridade, a disponibilidade, a segurança e a segurança geral dos

dados. As falhas de controle nessas áreas podem levar a fraudes.

Dica profissional: há várias normas que são revisadas com frequência. Recomendamos que você se mantenha atualizado com as mudanças e explore mais estruturas, controles e conformidade. Duas sugestões para pesquisa: a Lei Gramm-Leach-Bliley e a Lei Sarbanes-Oxley.

Modulo 4:

Ferramentas comuns de Segurança Cibernetica

Log- registro de eventos que ocorre nos sistemas de uma organização. Como logins de funcionarios no computador ou acessar serviços baseados na web. Logs ajudam profissionais a identificar vulnerabilidades e possiveis violações de segurança.

Security Information and event Management (SIEM) tool

Um aplicativo que coleta e analiza dados de log para monitorar atividades criticas em uma organização. Coletam infos. em tempo real e permitem analistas de segurança indentificar possíveis violações à medida que elas acontecem. Um **registro** A é um registro de eventos que ocorrem

Programming(programar)

Usado para criar um conjunto especifico de instruções para um computador para executar tasks. Os analistas de segurança usam linguagens de programação, como Python, para executar a automação. **Automação** é o uso da tecnologia para reduzir o esforço humano e manual na execução de tarefas comuns e repetitivas. A automação também ajuda a reduzir o Risco de erro humano.

linux - Sistema operacional de código aberto e disponivel publicamente.

Structured query Language(SQL)

Linguagem de programação usada para criar, interagir e solicitar infos de um banco de dados. Pode haver milhões de pontos de dados em um

nos sistemas de uma organização. Dependendo da quantidade de dados com que estiver trabalhando, pode levar horas ou dias para filtrar os dados de registro por conta própria. As Ferramentas SIEM reduzem a quantidade de dados que um Analista de dados deve analisar, fornecendo alertas para tipos específicos de ameaças, Riscos e vulnerabilidades.

As ferramentas SIEM fornecem uma série de painéis que organizam visualmente os dados em categorias, permitindo que os usuários selecionem os dados que desejam analisar. Diferentes ferramentas SIEM têm diferentes tipos de painéis que exibem as informações às quais você tem acesso.

As ferramentas SIEM também vêm com diferentes opções de hospedagem, inclusive no local e na Nuvem. As organizações podem escolher uma opção de hospedagem em vez de outra com base na experiência de um membro da equipe de segurança. Por exemplo, como uma versão hospedada na nuvem tende a ser mais fácil de configurar, usar e manter do que uma versão no local, uma equipe de Segurança menos experiente pode escolher essa opção para sua organização.

banco de dados. Um **ponto de dados** é uma informação específica.

DataBase(banco de dados)- Uma coleção organizada de infos ou dados

Python- Usado para performar tasks que são repetitivas e demoras e requerem alto nivel de detralhes e precisão

Vulnerabilidade da Web

Uma **vulnerabilidade na web** é uma falha exclusiva em um aplicativo da web que um agente de ameaças poderia exploit usando códigos ou comportamentos maliciosos para permitir acesso não autorizado, roubo de dados e implantação de malware.

Software antivírus

O software antivírus é um software usado para prevenir, detectar e eliminar malware e vírus. Também é chamado de anti-malware. Dependências do tipo de software antivírus, ele pode examinar a memória de um dispositivo para encontrar padrões que indiquem a presença de malware.

Sistema de detecção de intrusão (IDS)

Um **Sistema de detecção de intrusão** (IDS) é um aplicativo que monitora a atividade do sistema e alerta sobre possíveis intrusões. O

Ferramentas comuns de SIEM: Splunk e Chronicle.

Splunk é uma plataforma de análise de dados, Splunk Enterprise é uma ferramenta auto-hospedada usada para reter, analisar e pesquisar os dados de registro de uma organização.

Outra Ferramenta SIem é o Google Chronicle, sendo uma ferramenta SIEM nativa da nuvem que armazena dodos de segurança para pesquisa e análise. Permite a entrega rapida de novos recursos.

outras ferramentas de seguranças são:

- playbooks
- Analisadores de protocolo de rede.

Playbook - É um manual que providencia detalhes sobre qualquer ação operacional. O objetivo é: o**rientar os analistas em uma série de etapas para concluir tarefas específicas relacionadas à segurança**. Exemplo: como responder incidentes

Os manuais também ajudam a garantir que você esteja seguindo os protocolos e procedimentos adequados. Ao trabalhar em um caso forense, há dois manuais que podem ser seguidos:

sistema verifica e analisa os pacotes de dados, que transportam pequenas quantidades de dados por uma rede. A pequena quantidade de dados facilita o processo de detecção para que um IDS identifique possíveis ameaças a dados confidenciais. Outras ocorrências que um IDS pode detectar podem incluir roubo e acesso não autorizado.

Criptografia

A criptografia torna os dados ilegíveis e difíceis de decodificar para um usuário não autorizado; seu principal objetivo é garantir a confidencialidade dos dados privados. **Criptografia** de dados é o processamento de conversão de dados de um formato legível em um formato criptograficamente codificado. **Codificação criptográfica** significa converter texto simples em texto **criptografado** seguro. **O texto** simples é uma informação não criptografada e **o texto criptografado seguro** é o resultado da criptografia.

Observação: a codificação e a criptografia têm finalidades diferentes. A codificação usa um algoritmo de conversão pública para permitir que sistemas que usam representações de dados diferentes compartilhem informações.

- O primeiro tipo de manual que pode ser consultado é chamado de manual **da cadeia de custódia** . A cadeia de custódia é o processo de documentar a posse e o controle de evidências durante o ciclo de vida de um incidente. AS Como Analista de segurança envolvido em uma análise forense, você trabalhará com os dados do computador que foram violados. Você e a Equipe forense também precisarão documentar quem, o quê, onde e por que você tem as evidências coletadas. As evidências são de sua responsabilidade enquanto estiverem em sua posse. As evidências devem ser mantidas em segurança e acompanhadas. Toda vez que uma evidência é movida, ela deve ser relatada. Isso permite que todas as partes envolvidas saibam exatamente onde a evidência está em todos os momentos.

Teste de penetração

O teste de penetração, também chamado de pen testing, é o ato de participar de um ataque simulado que ajuda a identificar vulnerabilidades em sistemas, redes de computadores, sites, aplicativos e processos. É uma Avaliação de risco completa que pode avaliar e identificar ameaças externas e internas, bem como pontos fracos.

- O segundo manual que sua Equipe pode usar é chamado de manual de **proteção e preservação de evidências** . Proteger e preservar evidências é o processamento de trabalho adequado com evidências digitais frágeis e voláteis. Como analista de segurança, é fundamental entender o que são evidências digitais frágeis e voláteis e por que existe um procedimento. Ao seguir este manual, você consultará a **ordem de volatilidade**, , que é uma sequência que descreve a ordem dos dados que devem ser preservados, do primeiro ao último. Ela prioriza os dados voláteis, que são aqueles que podem ser perdidos se o dispositivo em questão for desligado, independentemente do motivo. Durante a realização de uma investigação, o gerenciamento inadequado de evidências digitais pode comprometer e

alterar essas evidências. Quando a evidência é gerenciada de forma inadequada durante uma investigação, ela não pode mais ser usada. Por esse motivo, a primeira prioridade em qualquer investigação é preservar adequadamente os dados. Você pode preservar os dados fazendo cópias e conduzindo sua investigação usando essas cópias.

Analisadores de protocolo de rede.(packet sniffer) - Ferramenta designada para capturar e analisar o tráfego de dados de uma rede. Isso significa que a ferramenta mantém um registro A de todos os dados que um computador da rede de uma organização encontra. Como: tcpdump e Wireshark